



UNIDAD 6. SISTEMAS DE DETECCIÓN Y PREVENCIÓN DE INTRUSIONES (IDPS)

EE: SEGURIDAD EN REDES DE CÓMPUTO
INGENIERÍA DE CIBERSEGURIDAD E INFRAESTRUCTURA DE CÓMPUTO

MRT. MARTHA ELIZABET DOMÍNGUEZ BÁRCENAS

Detección de intrusiones



La **detección de intrusiones** es el proceso de supervisar los eventos que se producen en un sistema informático o una red y analizarlos en busca de indicios de posibles *incidentes*.

Incidentes. Infracciones o amenazas inminentes de infracción de las políticas de seguridad informática, las políticas de uso aceptable o las prácticas de seguridad estándar.

Causas de un incidente: malware, accesos no autorizados, uso indebido de credenciales, errores involuntarios (ej., IP errónea).

Sistema de detección de intrusiones (IDS). Programa informático que automatiza el proceso de detección de intrusiones.

Sistema de prevención de intrusiones (IPS). Programa informático que cuenta con todas las funciones de un sistema de detección de intrusiones y que, además, puede intentar detener posibles incidentes.

Se utiliza la abreviación **IDPS** para referirse a ambos sistemas: **Sistemas de Detección y Prevención de Intrusiones**.

Aplicaciones de las tecnologías IDPS

- Enfoque en la identificación de posibles incidentes.
- Informe que administrador de seguridad para que pueda tomar acciones rápidas y minimizar el daño causado por el incidente.
- No detectan cuando un sistema ya fue comprometido.
- Pueden guardar registro de la información para uso posterior.
- Ejemplos de uso:
 - Identificación de tráfico que viola las políticas de la organización
 - Monitoreo de transferencia de archivos e identificación de archivos sospechosos.
 - Identificación de reconocimiento de actividad (ej., escaneo de puertos)

Otras aplicaciones de los IDPS

- Identificación de problemas en las políticas de seguridad.
 - Por ejemplo, a través de la identificación de errores en las reglas del firewall (paso de paquetes que debieron ser bloqueados).
- Documentación de amenazas para la organización.
 - Gracias a los registros de amenazas se puede analizar la frecuencia y características de los ataques, ayudando a identificar las medidas de seguridad apropiadas.
- Disuadir a personas de infringir políticas de seguridad
 - Al estar conscientes de que sus acciones pueden ser monitoreadas (riesgo de detección).

Funciones clave de los IDPS

- Registro de información sobre los eventos observados
 - Generalmente se almacena localmente, pero podría enviarse a sistemas de log centralizado o a soluciones como los sistemas de gestión de información y eventos (SIEM).
- Notificación eventos observados al administrador de seguridad
 - Alertas a través de correo electrónico, páginas, mensajes a través de una interfaz de usuario, sistemas de log y programas definidos por el usuario.
- Generación de reportes
 - Resumen de eventos monitoreados

Técnicas de respuesta de los IPS

- Detiene el ataque por si mismo
 - Termina la conexión o sesión utilizada para el ataque
 - Bloquea acceso (dirección IP u otro atributo del atacante)
 - Bloquea todo acceso al objetivo (host, servicio, aplicación u otro recurso)
- Modifica el entorno de seguridad
 - Cambia la configuración de otros controles de seguridad (como firewall, router, switch) para bloquear un ataque.
 - Incluso podría forzar la aplicación de parches de seguridad en un host.
- Modifica el contenido del ataque
 - Sustituye o elimina partes maliciosas del ataque para neutralizarlo (archivo adjunto en un correo, reempaquetado de la carga útil de un paquete descartando información de encabezados)

Precisión en la detección

- Los IDPS no pueden ofrecer una detección totalmente precisa.
- **Falsos positivos.** Cuando el IDPS detecta una actividad benigna como maliciosa.
- **Falsos negativos.** Cuando el IDPS no detecta una actividad maliciosa.
- No es posible eliminarlos.
- Generalmente se elige reducir los falsos negativos, pero se incrementan los falsos positivos.
 - Se requiere mayor análisis para diferenciarlos.

Metodologías de detección comunes

- Los IDPS utilizan una o más metodologías para la detección de incidentes.
- Dentro de las principales están:
 - Basada en firmas
 - Basadas en anomalías
 - Análisis de protocolos con estado

Detección badasa en firmas (1/2)

- **Firma.** Patrón que corresponde a una amenaza conocida
- **Signature-Based Detection.** Proceso de comparar firmas contra eventos observados para identificar posibles incidentes.
- Ejemplos de firmas:
 - Intento de telnet con usuario root (violación a las políticas de la organización)
 - Correo electrónico con el subject “Free pictures!” y un archivo adjunto llamado freepics.exe (característica de una forma de malware)
- Muy efectiva para la detección de amenazas conocidas.
- Ineficaz para detección de amenazas no conocidas hasta entonces, o camufladas mediante técnicas de evasión.
 - Ejemplo:
 - Si en el ejemplo anterior, el nombre del archivo se cambia por freepics2.exe no habrá coincidencia con la firma (freepics.exe)

Detección badasa en firmas (2/2)

- Poco entendimiento del comportamiento de los protocolos.
- No puede dar seguimiento al estado de una conexión.
- No detectan ataques que consten de varios eventos, si ninguno de ellos contiene un indicio claro de que se trata de un ataque.

Detección basada en anomalías (1/3)

- Anomaly-based detection
- Proceso de comparar definiciones de lo que se considera una **actividad normal** con los eventos observados para identificar desviaciones significativas.
- Utiliza **perfiles** que representan un comportamiento normal de elementos como usuarios, host, conexiones de red o aplicaciones.
 - Derivados del **monitoreo de características** de una actividad típica sobre un periodo de tiempo dado.
 - Ejemplo: Un perfil de una red muestra que la actividad Web consume un promedio del 13% del ancho de banda durante un día de trabajo típico.
 - **Criterios de desarrollo de perfiles:** número de correos electrónicos enviados por un usuario, número de fallas de intento de inicio de sesión en un host, nivel de uso del procesador para un host en un periodo de tiempo.

Detección basada en anomalías (2/3)

- Puede ser muy efectiva detectando amenazas desconocidas previamente
- Ejemplo:
 - Computadora infectada con un nuevo tipo de malware
 - El malware podría:
 - Consumir recursos de procesamiento,
 - Enviar un gran número de correos electrónicos
 - Iniciar un gran número de conexiones
 - Realizar otros comportamientos significativamente diferentes del perfil establecido para la computadora.
- **Periodo de entrenamiento.** Perfil inicial generado sobre un periodo de tiempo (días o semanas)

Detección basada en anomalías (3/3)

- Dos tipos de perfiles:
 - **Perfiles estáticos.** Una vez generado no cambia, a menos que el IDPS sea configurado para generar un nuevo perfil.
 - Eventualmente será inexacto, por lo que se tienen que regenerar periódicamente.
 - **Perfiles dinámicos.** Se ajusta constantemente con eventos adicionales que son observados.
 - La medida de comportamiento “normal” cambia, ya que los sistemas y redes cambian con el tiempo.
 - Susceptibles a intentos de evasión por parte de los atacantes.
 - Ejemplo:
 - Un atacante puede generar un poco de actividad maliciosa ocasionalmente y lentamente incrementar la frecuencia y cantidad de actividad.
 - Si la tasa de cambio es suficientemente lenta, el IDPS detecta la actividad como normal.
- Ambientes muy diversos o dinámicos, pueden generar muchos falsos positivos

Análisis de protocolos con estado (1/4)

- Proceso de comparar perfiles predeterminados de **funciones generalmente aceptadas**, como **actividades de protocolo benignas para cada estado del protocolo**, con los **eventos observados** y con el fin de identificar desviaciones.
- Se basa en **perfiles universales desarrollados por los proveedores** que especifican como deben y como no deben utilizarse determinados protocolos.
- **Con estado**. Significa que el IDPS es capaz de comprender y rastrear el estado de los protocolos de red, transporte y aplicación (que tienen noción de estado).

Análisis de protocolos con estado (2/4)

- Ejemplo de protocolo con estado: FTP
 - Inicio de sesión en estado No Autenticado.
 - Los usuarios pueden ejecutar muy pocos comandos (consulta de ayuda o introducir credenciales).
 - Cuando se produce un intento de autenticación FTP, el IDPS puede determinar si fue exitoso buscando el estado de la respuesta.
 - Cuando el usuario se autentica correctamente, la sesión pasa al estado Autenticado y se esperan múltiples posibilidades de comandos por parte del usuario.
 - Una actividad sospechosa, sería el intento de ejecución de alguno de estos comandos, en estado No Autenticado.

Análisis de protocolos con estado (3/4)

- Permite identificar secuencias de comandos inesperadas
 - Mismo comando repetidamente
 - Comando sin haber emitido otro del que depende
- Con protocolos que realizan autenticación
 - El IDPS puede realizar un seguimiento del autenticador utilizado en cada sesión y registrar el utilizado en una sesión sospechosa.
- Puede comprobar aspectos como la longitud mínima y máxima de los argumentos para un comando (ej., nombre de usuario).
- Se basan principalmente en estándares de protocolo de proveedores y de organismos de normalización como la IETF.
 - Cuando el protocolo no explica de forma exhaustiva los detalles del protocolo, se generan variaciones en las distintas implementaciones

Análisis de protocolos con estado (4/4)

- Consumen muchos recursos, debido a la complejidad del análisis.
- No pueden detectar ataques que no violen las características de comportamiento “aceptable” de un protocolo.
 - Ejemplo: la generación de muchas acciones benignas en un periodo de tiempo breve, para generar un ataque de DoS.
- El modelo de protocolo utilizado por un IDPS podría entrar en conflicto con la forma en que se implementa el protocolo en una aplicación o sistema operativo específicos.

Tipos de Tecnologías IDPS

- **Basados en red.**
 - Monitorean tráfico de un segmento de red particular, analizan su actividad y la de los protocolos para detectar actividad sospechosa.
 - Se suele implementar en los límites de la red (cerca del firewall, router o servidores VPN)
- **Inalámbricos.**
 - Monitorea tráfico de redes inalámbricas
 - No pueden identificar actividad sospechosa en protocolos de capa superior (como TCP o UDP)
- **Basados en Análisis de Red (NBA)**
 - Examina el tráfico de red para identificar amenazas que generan flujos inusuales (DDoS, malware (gusanos, puertas traseras), incumplimiento de políticas.
 - Se suelen implementar para supervisar los flujos internos de una organización o el tráfico entre redes.
- **Basados en Host**
 - Supervisa las características de un único host y los eventos que se producen en él en busca de actividades sospechosas
 - Características: tráfico de red (solo del host), registros del sistema, procesos en ejecución, actividad de las aplicaciones, acceso, modificación de archivos, cambios en la configuración del sistema y de las aplicaciones.
 - Utilizados en host críticos como servidores,

Componentes típicos de una solución IDPS

- Sensor o Agente
 - Monitorea y analiza actividad
 - Sensor, para IDPS basados en red, basados en análisis de red e inalámbricos.
 - Agente, para IDPS basados en host.
- Servidor de Gestión
 - Dispositivo centralizado que recibe y analiza información de los sensores o agentes.
 - Disponible como dispositivo (appliance) o como software.
 - Pequeñas implementaciones de IDPS podrían no usar servidor de gestión, grandes implementaciones podrían utilizar múltiples servidores.
- Servidor de Base de Datos
 - Repositorio para la información recabada por los sensores, agentes y/o servidores.
- Consola
 - Interfaz para el usuario y administrador del IDPS.
 - Algunas consolas se utilizan solo para gestión (configuración de sensores o agentes, aplicación de actualizaciones).
 - Otras consolas se usan estrictamente para monitoreo y análisis.
 - Otras para ambas tareas.

Capacidades de detección (1/2)

- **Umbrales (Thresholds).**

- Especifica el máximo valor aceptables (X fallos de intento de conexión en 1 min.; X caracteres para el nombre de un archivo).
- Utilizado para detección basada en anomalías o para análisis de protocolos con estado

- **Listas blancas y Listas negras (Blacklists and Whitelists).**

- ***Lista negra.*** Lista de entidades asociadas con actividades maliciosas (host, números de puerto, usuarios, aplicaciones, tipos y códigos ICMP, URLs, archivos, extensiones, etc.).
 - Se utilizan para asignar alta prioridad a las alertas que hacen match con las entradas de la blacklist.
- ***Listas blancas.*** Lista de entidades identificadas como benignas
 - Permiten reducir los falsos positivos asociados con actividades inofensivas conocidas
- Comunmente utilizadas en detección basada en firmas y análisis de protocolo con estado.

Capacidades de detección (2/2)

- **Configuración de alertas.** Personalización del cada tipo de alerta
 - Activar/Desactivar.
 - Configurar nivel predeterminado de prioridad o de severidad.
 - Especificar que información debería ser registrada y qué métodos de notificación debería ser utilizado.
- **Edición y Visualización de Código.**
 - Algunos IDPS permiten al administrador visualizar el código de los programas relacionados con la detección (ayuda en la identificación de falsos positivos)

IDPS basados en red (NIDPS)

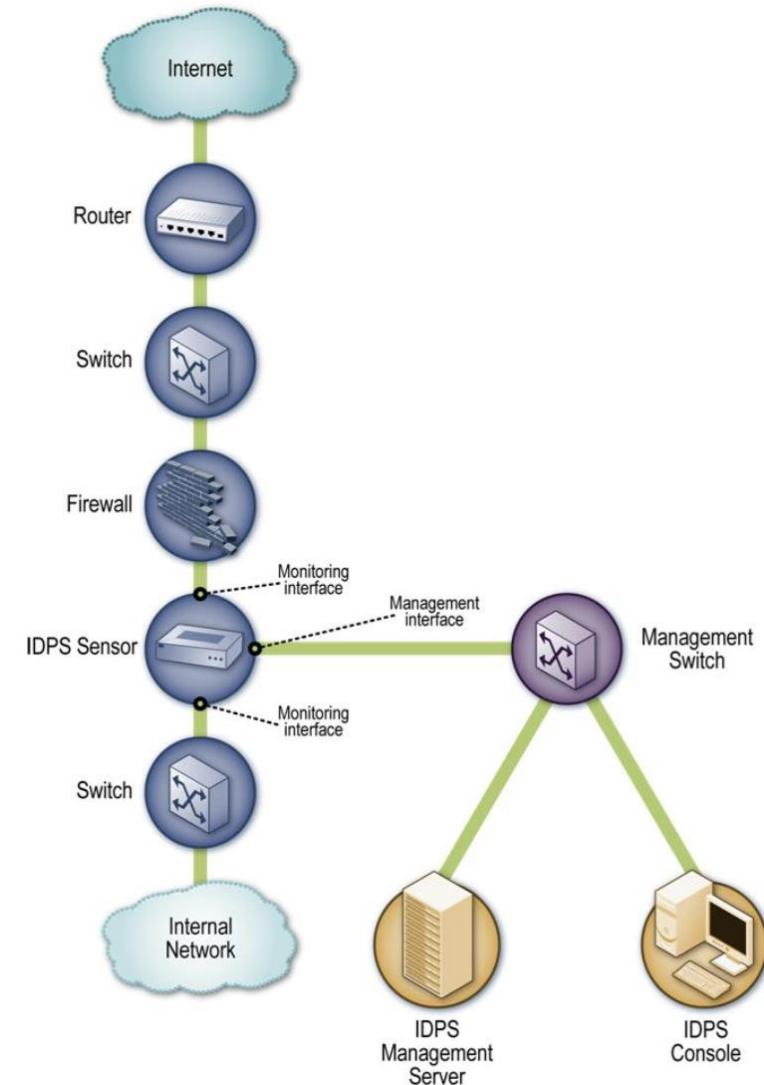
- Monitorean tráfico de una red particular
- Analizan protocolos de red, transporte y aplicación para identificar actividad sospechoza.

Componentes

- Componentes de un IDPS basado en red típico
 - Sensores
 - Uno o más servidores de gestión
 - Múltiples consolas
 - Uno o más servidores de BD (opcional)
- Las tarjetas de red trabajan en modo promiscuo para aceptar todos los paquetes entrantes detectados, sin importar su destino.
- Los sensores están disponibles en dos formatos:
 - **Dispositivo** (Appliance). Incluye tarjetas de red (NIC) y controladores especializados para la captura eficiente de paquetes.
 - **Solo Software**. Puede incluir un S.O. personalizado o instalarse sobre un S.O. estándar como cualquier otra aplicación.

Arquitectura de red y ubicación de sensores...

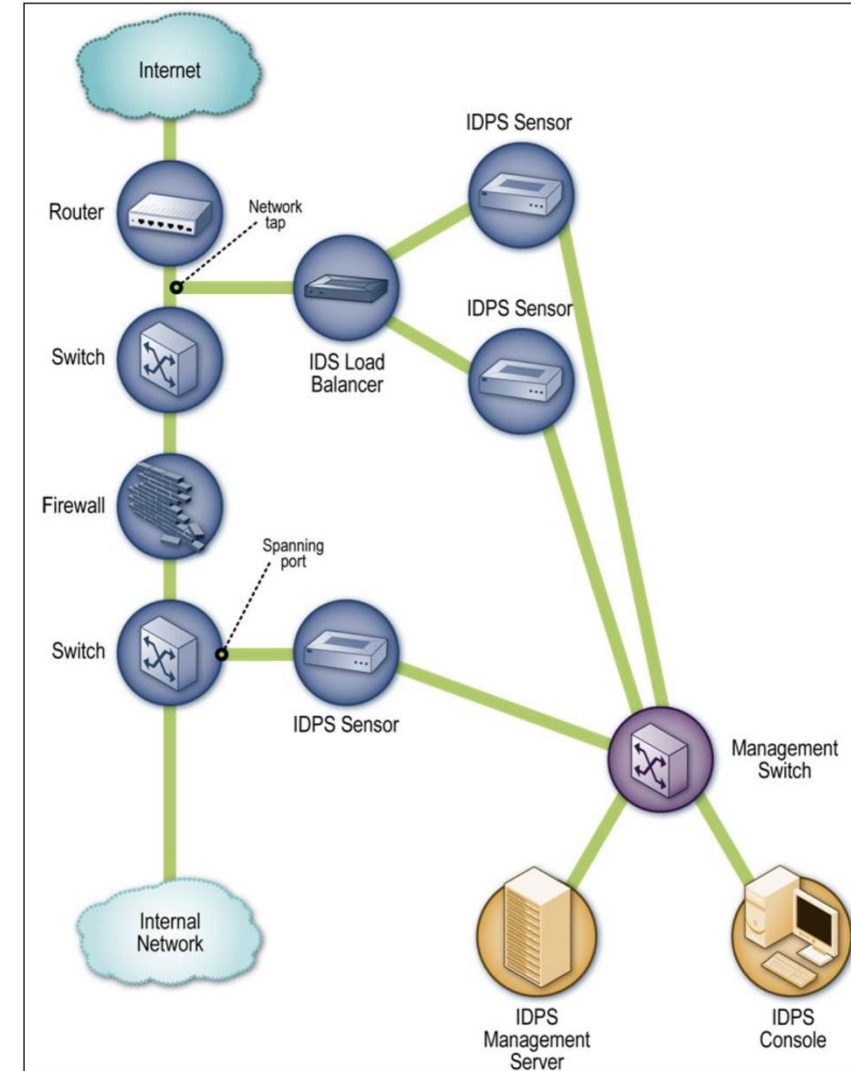
- Los sensores pueden instalarse en uno de dos modos:
- **En línea (Inline)**
 - El tráfico de red que supervisa debe pasar a través de él (misma ubicación del Firewall)
 - Ubicación: en los bordes entre redes.
 - Recomendado si se utilizarán capacidades de prevención.



...Arquitectura de red y ubicación de sensores

- **Pasivo (Passive).**

- El sesor pasivo supervisa una copia del tráfico de la red real.
- El tráfico no pasa a través del sensor.
- Pueden supervisar tráfico mediante varios métodos:
 - **Puerto de monitorización (Spaning Port).** Puerto especial de un switch capaz de ver todo el tráfico que pasa por el dispositivo.. Se conecta un sensor al puerto de monitorización.
 - **Derivador de red (Network Tap).** Conexión directa entre un sensor y el propio medio físico de red (p.e., un cable de fibra óptica), que proporciona una copia de todo el tráfico al sensor.
 - **Balanceador de carga IDS.**
 - Dispositivo que dirige el tráfico de red hacia los sistemas de monitorización, incluidos los sensores IDPS.
 - Puede recibir copias del tráfico procedentes de uno o varios puertos de monitorización, dispositivos de derivación de red o agregar tráfico de diferentes redes.
- Puerto que monitorea copias del tráfico, no proporciona una forma confiable para que el sensor impida que el tráfico llegue a su destino.



Capacidades de Detección (1/2)

- Reconocimiento y ataques de la capa de Aplicación. Ejemplos:
 - Ganner grabbing (captura de encabezados). Conexión a un servicio para obligarlo a revelar su identidad)
 - Buffer overflows
 - Format string attacks. Manipulación de instrucciones de programas para introducir código que comprometa al sistema.
 - Password guessing
 - Malware transmission
- Reconocimiento y ataques de la capa de Transporte. Ejemplos:
 - Port scanning
 - Unusual packet fragmentation
 - SYN floods

Capacidades de Detección (2/2)

- Reconocimiento y ataques de la capa de Red. Ejemplos:
 - Spoofed IP addresses
 - Illegal IP header values
- Servicios de aplicación imprevistos. Ejemplos: puertas traseras, ejecución de servicios no autorizados.
 - Mediante Análisis de Protocolos con Estado, cambios en el flujo de datos o puertos abiertos.
- Violación de políticas. Ejemplos:
 - Sitios web inadecuados
 - Protocolos de aplicación prohibidos

Capacidades de Prevención

- Finalización de sesiones TCP
 - Envío de paquetes TCP reset a los dos endpoints (sesion sniping)
- Implementación de firewall en línea. Para descartar o rechazar actividad de red sospechoza.
- Limitación de uso de ancho de banda. En ataques como DoS o de distribución de malware.
- Alteración de contenido malicioso. Reemplazo de encabezados maliciosos (sanitización de paquetes).
- Reconfiguración de dispositivos de red (firewalls, routers, switches). A partir de características como direcciones IP o números de puerto.
- Ejecución de un programa o script

Soluciones de NIDPS Open Source

- Snort
 - Estandar de facto en la industria
 - Análisis basado en firmas
- Suricata. Alternativa moderna a Snort
- Zeek (antes Bro)
 - Utiliza lenguaje de programación propio para generar script de detección de anomalías.

Suricata



Instalación en Debian 12

- Añadir repositorio de backports:
 - `echo "deb http://deb.debian.org/debian bookworm-backports main" > /etc/apt/sources.list.d/bookworm-backports.list`
- Actualizar repositorios e instalar:
 - ***apt-get update***
 - ***sudo apt install -y suricata -t bookworm-backports***
- Archivo ***/etc/suricata/suricata.yaml***
 - Interfaz de escucha: sección af-packet
 - Interfaz de captura de paquetes: sección pcap
 - Red local: sección address-groups
- Actualizar Suricata: ***suricata-update***
- Validar sintaxis: ***suricata -T -c /etc/suricata/suricata.yaml -v***
- Reiniciar servicio: `systemctl restart suricata`

Reglas

- **Action** – Que sucederá cuando haya una coincidencia con la regla
- **Header** – Define el protocolo, dirección IP, puertos y dirección de la regla
- **Rule Options** – Define detalles de la regla.

- Ejemplo:

```
alert http $HOME_NET any -> $EXTERNAL_NET any (msg:"HTTP GET Request Containing Rule in URI"; flow:established,to_server; http.method; content:"GET"; http.uri; content:"rule"; fast_pattern; classtype:bad-unknown; sid:123; rev:1;)
```


Acciones

- **Alert** – genera una alerta
- **Pass** – detiene el análisis posterior del paquete
- **Drop** – descarta paquete y genera alerta
- **Reject** o **rejectsrc**- enviar un error RST/ICMP de «no se puede llegar» al remitente del paquete correspondiente.
- **Rejectdst** – envía un paquete de error RST/ICMP al destinatario del paquete coincidente.
- **Rejectboth** – envía paquetes de error RST/ICMP a ambos extremos de la comunicación.

Header - Protocolo

- Ip (cualquier paquete IP)
- tcp
- udp
- icmp (ambos ICMPv4 y ICMPv6)
- icmpv4
- icmpv6
- ipv4/ip4 – solo IPv4
- ipv6/ip6 - solo IPv6
- pkthdr (para coincidencia de paquetes con eventos)
- ether – paquetes Ethernet
- arp – paquetes ARP

- Algunos protocolos de capa 7
 - http
 - Tls
 - Quic
 - ftp
 - Smb
 - Dns
 - Dhcp
 - Ssh
 - Sntp
 - Imap
 - Pop3
 - Nfs
 - Snmp
 - telnet

Header - origen, destino y dirección

\$HOME_NET any -> **\$EXTERNAL_NET** any

- **ORIGEN Y DESTINO**

- **\$HOME_NET** y **\$EXTERNAL_NET** – definidos en archivo suricata.yaml
- Se puede especificar
 - Dirección de RED/CIDR: 192.168.1.0/24,
 - Negación: ![10.0.0.1]
 - Agrupación: [1.1.1.1, 1.1.1.2]

- **PUERTOS**

- Any
- Número
- Rango: [80:100]
- Grupo: [80,81,82,100]
- Negación: !80

- **DIRECCIÓN**

- Source -> destination
- Source => destination
 - Respeta direccionalidad de -> pero permite coincidencia en transacciones bidireccionales
- Source <> destination
 - Se aplica en ambos sentidos

Rule options

- Entre paréntesis
- Formato:
 - (PALABRA_CLAVE: CONFIGURACIÓN; PALABRA_CLAVE: CONFIGURACIÓN;PALABRA_CLAVE;)
 - CONFIGURACIÓN. Solo si la palabra clave lo permite
- Ejemplo:
 - (msg:"[TEST]- Coincidencia detectada"; flow:established,to_server; sid:123; rev:1;)

Ejemplo básico:

- Detectar ping
 - Crear archivo de reglas en: /var/lib/suricata/rules/misreglas.rules
 - ***alert icmp \$HOME_NET any -> \$EXTERNAL_NET any (msg:"[TEST-PING] – Ping detectado hacia el exterior"; sid: 1000001; rev:1;)***
 - Declarar nuevo archivo en suricata (en suricata.yaml)
 - Agregar a sección rule-files:
 - Reiniciar servicio
 - Probar reglas
- Nota:
 - Es importante comprobar previamente la sintaxis después de hacer cambios en el archivo de reglas:
suricata -T -c /etc/suricata/suricata.yaml -v
 - Para cambios posteriores en reglas, se puede forzar recarga de archivos con: ***kill -USR2 \$(pidof suricata)***

Archivos de Log - Suricata

- Ruta: /var/log/suricata:
 - **fast.log** – Alertas rápidas en texto plano
 - **eve.log** – Extensible Event Format
 - Estructurado en formato json
 - Agrega metadatos sobre los eventos detectados
 - Estándar para integrar con herramientas de análisis de seguridad como los SIEM (Security Information and Event Management)
 - **suricata.log** – Registra el comportamiento de suricata
 - Texto plano
 - Útil para solución de problemas con suricata
 - **stat.log** – Registra métricas de rendimiento
 - Se actualiza constantemente
 - Número de paquetes procesados, paquetes perdidos, uso de memoria, etc
 - Texto plano
 - Útil para tomar decisiones de optimización y “tuneo” del IDPS (con base en el rendimiento del hardware, por ejemplo)

Consulta de logs

- `tail -f /var/log/suricata/fast.log`
- `tail -f /var/log/suricata/eve.json | jq`

```
root@vbox:/var/lib/suricata/rules# tail -f /var/log/suricata/eve.json | jq 'select(.event_type=="alert") | {timestamp, src_ip, src_port, alert: .alert.signature, direction, dest_ip, dest_port}'
```

Ejercicio

- Agregar alerta que detecte conexiones SSH al servidor desde la red interna.
- Agregar alerta que detecte conexiones hacia www.uv.mx desde la red interna.

Suricata como IPS (1/2)

- Habilitar Suricata en modo IPS (inline)
- Dos formas en que un IDPS puede procesar datos
 - Modo AF_PACKET (Inline). Pasarela. Suricata analiza el tráfico que entra por la interfaz A y si es seguro, sale por la interfaz B
 - Modo NFQUEUE. Intercepta el tráfico justo antes de que llegue a las aplicaciones locales (tráfico destinado al host)
- NFQUEUE
 - Netfilter Queue
 - Objetivo (target) en iptables que permite delegar el tratamiento de un paquete a una aplicación (no al kernel del SO)
 - Suricata recibe el paquete, lo analiza y puede responder con una de dos opciones:
 - NF_ACCEPT. El kernel lo libera
 - NF_DROP. El kernel lo destruye

Suricata como IPS (2/2)

- Ejemplo:
 - Detectar y bloquear intento de ataque de fuerza bruta por SSH
- Firewall debe enviar el tráfico SSH entrante hacia Suricata, antes de procesarlo
 - ***iptables -A INPUT -p tcp --dport 22 -j NFQUEUE --queue-num 0***
 - (cola número 0)
- Arrancar suricata indicando que escuche la cola de NFQUEUE
 - ***suricata -q 0 -c /etc/suricata/suricata.yaml***

Regla

- `drop tcp $HOME_NET any -> 10.10.10.10 22 (msg:"IPS: Bloqueado intento de Fuerza Bruta SSH"; flow:to_server,established; flags:S; detection_filter:track by_src, count 5, seconds 60; sid:1000002; rev:1;)`

Script de ataque

```
for i in {1..7}
do
    ssh -o ConnectTimeout=2 usuario_falso@[IP_DE_SURICATA]
done
```

Referencias

- Scarfone, K., & Mell, P. (2007). *Guide to Intrusion Detection and Prevention Systems (IDPS)* (NIST Special Publication (SP) 800-94). National Institute of Standards and Technology.
<https://doi.org/10.6028/NIST.SP.800-94>
- *Suricata User Guide—Suricata 8.0.5 documentation.* (s/f).
<https://docs.suricata.io/en/suricata-8.0.5/>